FICHE 1 - PILOTER LA SÉCURITÉ DES DONNÉES

Mettre en place et maintenir dans la durée la protection des données personnelles exigée par le RGPD et les cadres sectoriels.

L'intégration de la protection des données personnelles dans les processus de décision de l'organisme permet d'en assurer la prise en compte dans la durée et aux moments clés d'arbitrages des budgets et des projets.

Les précautions élémentaires

- **Impliquer la direction** et formaliser des objectifs généraux en matière de sécurité et de protection des données personnelles, validés par la direction de l'organisme.
- **Recenser** (à travers le registre[5]) **les traitements de données personnelles**, automatisés ou non, les données traitées (ex. : fichiers clients, contrats) et les supports sur lesquels ces traitements reposent :
  - les matériels (ex. : serveurs, ordinateurs portables, disques durs) ;
  - les logiciels (ex. : systèmes d'exploitation, logiciels métier) ;
  - les ressources d'informatique en nuage (*cloud*) utilisés (ex. : SaaS, PaaS, IaaS) ;
  - les canaux de communication logiques ou physiques (ex. : connexions filaires, Wi-Fi, Internet, échanges verbaux, coursiers) ;
  - les supports papier (ex. : documents imprimés, photocopies) ;
  - les locaux et installations physiques où se situent les éléments précédemment cités (ex. : locaux informatiques, bureaux).

  Formaliser des schémas d'interconnexions et de flux de données entre les différents composants des systèmes d'information. Le registre et les schémas doivent être mis à jour lors de chaque modification structurelle des traitements ou des composants des systèmes d'information.
- **Définir un plan d'action relatif à la sécurité informatique et mettre en œuvre les mesures techniques et organisationnelles définies** pour assurer la protection des données. Pour ce faire, deux approches complémentaires peuvent être mises en œuvre : d'une part, mettre en place les précautions élémentaires listées dans le présent guide (voir la check-list d'évaluation) et, d'autre part, compléter par des mesures spécifiques identifiées à l'aide d'analyses de risques[6] (voir la fiche n°20 - Analyse de risques). Toute nouvelle mesure décidée doit intégrer le plan d'action dont l'avancement est suivi régulièrement.
- **Contrôler périodiquement l'effectivité des mesures** techniques et organisationnelles pour s'assurer qu'elles remplissent bien l'objectif poursuivi (ex. : par la mise en place d'indicateurs). Vérifier en priorité les mesures mises en œuvre pour corriger des vulnérabilités identifiées ou pour prévenir des incidents qui se sont déjà produits.
- **Assurer un suivi avec la direction** en termes de gestion de risques informatiques à travers une revue de direction au moins annuelle. Elle doit permettre d'établir une synthèse et de prendre des décisions considérant :

5 « Le registre des activités de traitement », cnil.fr

6 L'article 35 du RGPD impose de mener une analyse d'impact relative à la protection des données (AIPD) pour certains types de traitements (voir « Ce qu'il faut savoir sur l'analyse d'impact relative à la protection des données (AIPD) », cnil.fr).